CS5292 · WEEK 5 · MODULE 3

ABC Bank Limited: documents provided for a C-RAF 2.0 Maturity Assessment

Domain 1 — Governance. Documents the assessor relied on for five Baseline Control Principles, plus related documents management supplied.

Sanitised teaching material. Re-typeset extracts of real governance documents; the institution's name, all personal names, addresses, systems, vendors and other identifying details have been changed or removed. Do not attempt to identify the organisation and do not share outside CS5292.

Index

Ref	Document	Nature
D01	Governance structure and three lines of defence	Extract from ABC Bank's annual risk self-assessment report (year-end 2024), Section 3 – System of Governance
D02	Terms of Reference — Risk Management and Compliance Committee (RMCC)	Version 7.0, September 2023 (extract)
D03	Group Business Continuity Management Policy (v3.1)	Extract. Policy owner: Head of Compliance. Group BCP Officer: Head of IT.
D04	Business Continuity Plan (v3.0)	Extract. Owner: Group Head of Business Operations. Approval date: August 2025.
D05	RMCC Report, Q1 2025 — Operational Risk: Cyber and Information Security	Extract from the quarterly RMCC pack (pages 35–38 of 68). Other sections redacted.
D06	RMCC Report, Q2 2025 (June 2025) — Cyber and Information Security	Extract from the quarterly RMCC pack, presented by the CRO. Other sections redacted.
D07	Minutes of the RMCC meeting — Q1 2025	Extract. Attendees: RMCC Chairperson (INED) and five committee members including the CEO; one director; the CRO; Legal. Most items redacted.
D08	Group IT Security Incident Response Plan	Extract. Cover page states "Version 2.0 — date last amended: May 2024".
D09	Cyber Risk Management Policy (v1.0)	Full document, abridged. Dated 31 December 2024.
D10	IT Key Risk Indicators — draft for discussion (August 2025)	Extract of a draft KRI worksheet prepared by Operational Risk for IT. Actual results columns (Oct–Dec 2025) are blank.
D11	Terms of Reference — Audit Committee	Version 4.0, 27 September 2023 (extract). Duties relating to the external auditor and to financial statements are omitted.
D12	Internal Audit Policy	Group policy, version 1.0 (extract). Owner: Head of Internal Audit. Classification: For internal use only.
D13	Board minutes — approval of the 2024 and 2025 Internal Audit plans	Extracts of two Board meeting minutes. Attendees shown by role; fees removed.
D14	Internal Audit report — Internal Controls Review: Cybersecurity	Report dated 3 March 2025, issued by the co-sourced internal audit provider. Fieldwork November 2024 – January 2025. Extract; machine names, file paths and product names removed.
D15	Internal Audit follow-up tracker — IT and cyber actions (2023 and 2024 audits)	Extract of the issue tracker maintained for the Audit Committee. Responsible persons shown by role.

Cited by the assessor but not in this pack: ***Group Cyber Security Policy****;* ***KRI report to the Q1 2026 RMCC / Board meeting****;* ***Audit Committee minutes / Internal Audit quarterly reports****. Treat these as open RFI items.*

DOCUMENT D01 · ABC BANK

Governance structure and three lines of defence

Extract from ABC Bank's annual risk self-assessment report (year-end 2024), Section 3 – System of Governance

3.1 Governance structure

ABC Bank has established a governance system in compliance with the Banking Ordinance and the HKMA Supervisory Policy Manual (including CG-1 Corporate Governance and IC-1 Risk Management Framework), while also aligning with prevailing international practice.

The governance structure is set out in the shareholder agreement, articles of association, board charter and Board Committee terms of reference. Together with the Executive Committee (EC), the Board sets the tone and assigns responsibilities for managing key risks.

The Board includes 3 independent non-executive directors (INEDs), 3 non-executive directors and 2 executive directors. Each Board Committee — Audit; Risk Management and Compliance; Nomination and Remuneration — is chaired by an INED.

3.2 Risk reporting structure

Level	Role in risk management
Board	Overall responsibility for risk management
Risk Management and Compliance Committee (RMCC)	Includes INEDs; makes recommendations to the Board
Chief Risk Officer (CRO)	Leads the risk management function; reports to the RMCC quarterly
Risk management function	Supports ERM implementation; monitors the risk profile; communicates mitigation strategies and remedial actions

The EC and functional heads meet on a regular basis to discuss current and future management matters. Risk management and compliance topics are a recurrent theme and link ERM with day-to-day management.

3.3 Three lines of defence

1st line — Business units	2nd line — Risk and Compliance	3rd line — Internal Audit
Day-to-day risk management; follow the risk process; apply internal controls and risk responses	Oversee risk management across the bank; provide guidance and direction; risk management framework, oversight and reporting	Independent assessment of risk management; ensure adequate risk control, effective risk management and oversight

The Compliance function, led by the Head of Compliance, ensures the consistency and quality of compliance policies and guidelines and organises training for staff and management, including on cybersecurity. Business and operational functions maintain domain-specific policies, guidelines and manuals that address key risks and delineate roles and responsibilities.

The Internal Audit function is independent and reports directly to the Board via the Audit Committee. It is co-sourced from an external professional services firm and operates under an Internal Audit Policy, following an annual risk-based plan approved by the Audit Committee and the Board.

DOCUMENT D02 · ABC BANK

Terms of Reference — Risk Management and Compliance Committee (RMCC)

Version 7.0, September 2023 (extract)

1 General

The RMCC of ABC Bank Limited was established by resolution of the Board of Directors. The scope of these Terms covers ABC Bank, its branches and representative offices. The RMCC has the authority of the Board to conduct any enquiry and review, and undertake actions it considers appropriate, on matters related to risk management and regulatory compliance, having due regard to applicable laws, regulations and guidelines issued by the relevant regulators. The risk management and compliance function has a direct reporting line to the RMCC.

2 Membership

Members are appointed by the Board; at least two shall be independent non-executive directors. The Chief Executive Officer (CEO) shall be a member. Members should possess adequate knowledge and experience in risk management and/or compliance.

3 Meetings

Meetings will be held quarterly but may be held more frequently as required. The CRO and other senior executives as the CEO deems appropriate shall attend. Management is obliged to supply the RMCC with adequate, complete and reliable information in a timely manner.

5 Duties (selected)

- (a) review and advise the Board on the establishment and oversight of an effective enterprise risk management (ERM) framework;
- (b) review and advise the Board on the risk strategy and risk appetite, including review of the risk appetite statement at least annually;
- (c) oversee the monitoring of risk appetite and risk limits by management and the remedial actions taken for any breaches;
- (d) review and approve major risk management policies and risk limits for material risks, in areas such as credit, market, liquidity, asset liability management, conduct, cyber risk, internal controls and data quality;
- (h) regularly report to the Board on matters of risk management and escalate issues of importance when necessary;
- (i) review and approve major compliance policies and guidelines, including code of conduct, AML/CTF/sanctions, data protection and cybersecurity, as well as the annual compliance plan;
- (k) review any significant risk, legal or compliance issues (including data protection and cybersecurity) raised by management and regulators, and oversee the steps taken by management;
- (m) oversee the resourcing for the risk management and compliance function.

6 Reporting procedures

Full minutes shall be kept. The RMCC shall report back to the Board and keep the Board fully informed of its decisions and recommendations on key or significant matters relating to risk management and compliance.

7 Approval by the Board

These Terms shall be reviewed on an annual basis and as needed. Amendments shall be recommended by the RMCC and approved by the Board.

Version	Issue date	Updated by	Approved by
1.0–2.0	2013	CEO / CRO	Board
3.0–6.0	2016–2019	CRO	RMCC / Board
7.0	September 2023	Deputy CRO	RMCC / Board

DOCUMENT D03 · ABC BANK

Group Business Continuity Management Policy (v3.1)

Extract. Policy owner: Head of Compliance. Group BCP Officer: Head of IT.

Version	Date	Change	Updated by	Approved by
1.0	Mar 2019	First issue	Chief Operating Officer	Board
2.0	Mar 2020	BCP support team; process refinements	Head of IT	RMCC / Board
3.0	—	Expanded to group-level policy; BCM principles; BCP separated from policy	Head of Compliance	RMCC / Board
3.1	May 2023	Reviewed by new Head of IT in role as Group BCP Officer	Head of IT	RMCC / Board
3.1	Jun 2025	Reviewed in Q2 2025; no updates required	Head of IT	RMCC / Board (for noting only)

1 Purpose

ABC Bank maintains a comprehensive business continuity management (BCM) programme to respond to business disruptions of varying size and scope. The policy aims to ensure that the framework for business continuity across the group is defined, communicated, approved and executed in a controlled manner in accordance with strategic goals. It defines the scope, objectives, methodology, roles and responsibilities, principles and standards of business continuity measures, including incident reporting and escalation.

2 Roles and responsibilities

Role	Responsibilities (summary)
Executive Committee	Sponsors BCM across the group
Head of Compliance (“Group Compliance”)	Defines the policy principles and requirements and their annual update; with the Group BCP Officer, establishes the BCM framework and guidance; defines BC metrics; maintains an opinion on compliance with the policy
Group BCP Officer (Head of IT)	Oversees policy implementation and operations; monitors BC metrics and escalates issues; develops and implements the Business Continuity Plan and IT Service Continuity Plan
Local Management	Ensures appropriate resourcing and funding; nominates the Local BCP Officer
Local BCP Officer	Operates the policy locally; policy monitoring; awareness

3 Minimum standards (selected)

- 3.1 Management must review and document risk appetite towards disruptive events annually; resource requirements must be allocated and documented in an annual BCM programme.
- 3.2 Annual Business Impact Assessment and Business Continuity Risk Assessment.
- 3.4 Annual testing of continuity strategies and an annual call-tree test.
- 3.5 BCM incidents handled in line with the ERM framework and Incident Severity Rating Matrix.
- 3.7 To ensure management has clear oversight of BCM matters, management reporting must be undertaken.

4 Review and updates

This Policy and any material amendments shall be approved by the Board. The BCP Officer shall arrange for this Policy and the BCP to be reviewed by the RMCC annually and as needed, including on major changes in leadership or staffing changes affecting the BCP.

DOCUMENT D04 · ABC BANK

Business Continuity Plan (v3.0)

Extract. Owner: Group Head of Business Operations. Approval date: August 2025.

Version	Date	Change	Updated by	Approved by
1.0	Mar 2019	First issue	Chief Operating Officer	Board
2.0	Mar 2020	BCP support team; call tree; roles	Head of IT	RMCC / Board
3.0	Aug 2025	Standalone BCP under the Group BCM Policy; refreshed for updated regulatory requirements on cyber and operational resilience: roles, crisis scenarios, critical functions, BIA, evacuation, call tree	Group Head of Business Operations	Executive Committee

2 Plan

- 2.0.2 A BCP Working Group, led by the Group Head of Business Operations, must be established to collectively own, maintain and enforce this document.
- 2.0.3 Primary ownership and enforcement of all obligations is exclusively the responsibility of the Group Head of Business Operations.
- 2.0.4 In the absence of the Group Head of Business Operations, the Chief Risk Officer shall carry out the role.

2.5 Annual review and approval

- 2.5.1 The BCP must be reviewed by the BCP Working Group at least annually, and as needed (e.g. major leadership or staffing changes).
- 2.5.2 This Plan must be reviewed and approved by the Executive Committee (EC). If the EC deems necessary, it may escalate any material issue to the RMCC / Board for information and/or approval of material amendments.
- 2.5.3 At a minimum, the BIA for each team and all contact information must be reviewed and updated annually.

3.5–3.6 Scenarios and testing

- Three generic scenarios: Building outage; Technology outage (primary data centre down, communication links down, malware / ransomware, business applications down) — rated Very High impact; Full outage (natural disaster).
- 3.6.1 The BCP Working Group must test the BCP at least once every calendar year, using one of the generic scenarios.
- 3.6.2 A test should include plan activation, call tree and communication channels, technical tests (system recovery, remote access), other emergency plans, and feedback from leaders.

Note the ownership: the BCM Policy (D03) names the Head of IT as Group BCP Officer responsible for developing the BCP; this Plan names the Group Head of Business Operations as owner and the Executive Committee as approver.

DOCUMENT D05 · ABC BANK

RMCC Report, Q1 2025 — Operational Risk: Cyber and Information Security

Extract from the quarterly RMCC pack (pages 35–38 of 68). Other sections redacted.

Cyber and Information Security

– 29% of laptops have been onboarded with an endpoint detection and response (EDR) tool. The target date for the remaining laptops is April 2025.

– 65 email impersonation attacks were detected and blocked. Emails were crafted to appear as if sent by the CEO.

– An email security rule has been implemented to detect and monitor outbound emails sent to personal email providers. Any leakage of confidential data will be escalated to the Compliance team.

Enhancements to IT General Controls

– A Privileged Access Management tool has been deployed, allowing secure storage and use of high-privilege admin accounts with approval, auditing and session recording.

– Windows 11 replacement for all laptops has started, with a standardised corporate build.

– A corporate mobile phone enhanced security policy is being tested.

IT General Controls and IT Security Update (selected rows)

#	Key control	Action	Source and rating	Target	Status
4	IT policies covering key domains	Establish a measurement and control framework to govern cyber risk management, including cybersecurity, business continuity, logical access, change management and computer operations	2023 ITGC audit · High	31 Dec 2024	Completed
5	IT Security Incident Response Plan	(1) Update the plan; (2) schedule testing of readiness for a cyber attack	2023 ITGC audit · High	31 Mar 2024 / 31 Dec 2024	Completed
11	Remote access controls	Identify unauthorised remote access software; implement secure remote access; scan for files containing credentials	2024 Cyber audit · Medium	1 Nov 2025	In progress
13	Network segmentation	Review firewall policies; implement a network jump host	2024 Cyber audit · Medium	31 Dec 2025	In progress
15	Email security	Scan all email attachments before download; quarantine policy for password-protected files	2024 Cyber audit · Low	30 Jun 2025 / 30 Jun 2026	In progress / Not started

DOCUMENT D06 · ABC BANK

RMCC Report, Q2 2025 (June 2025) — Cyber and Information Security

Extract from the quarterly RMCC pack, presented by the CRO. Other sections redacted.

Cyber and Information Security

- EDR deployment has reached 98% coverage of company laptops. Remaining devices are offline due to staff travel and will be updated on return.
- No email impersonation attacks were detected during the quarter.
- A new email security rule monitors outbound emails to personal accounts; suspected data leakage is escalated to Compliance.

IT General Controls enhancements

- A dedicated private connection to the cloud provider is being set up.
- A new corporate mobile phone build (April 2025) restricts app store access and prevents data download.
- Completed this quarter: migration of key applications to the cloud ahead of a third-party data centre exit; certificate-based VPN authentication and single sign-on; privileged access management policy; closure of high-risk items from the 2023 ITGC and cybersecurity audits.

The IT General Controls and IT Security Update table (as in D05) is repeated with updated statuses.

Neither the Q1 nor the Q2 pack contains a section on the status of the business continuity programme (BIA, BCP test results, call-tree test).

DOCUMENT D07 · ABC BANK

Minutes of the RMCC meeting — Q1 2025

Extract. Attendees: RMCC Chairperson (INED) and five committee members including the CEO; one director; the CRO; Legal. Most items redacted.

6.2.9 Enhancements to IT General Controls

It was NOTED that significant progress has been made in addressing issues identified in the FY23 internal audit review on IT general controls and cybersecurity. All high-risk issues related to IT general controls have been remediated in Q4 2024. The low-risk issues related to the use of vulnerable software components have also been resolved. It was NOTED that the IT team has undertaken the following enhancements: (i) a Privileged Access Management tool has been deployed; (ii) the Windows 11 replacement for all laptops has started; (iii) the corporate mobile phone enhanced security policy is being tested.

DOCUMENT D08 · ABC BANK

Group IT Security Incident Response Plan

Extract. Cover page states "Version 2.0 — date last amended: May 2024".

Document details	
Title	Group IT Security Incident Response Plan
Version	1.2
Owner	IT Function
Approval date	[DD MMM YYYY]
Effective date	[DD MMM YYYY]

Version	Issue date	Summary of key changes	Prepared / updated by	Reviewed / approved by
1.0		First issue		[Committee / Board]
2.0				[Committee / Board]

1 Introduction

This document sets out ABC Bank's Plan for reporting and dealing with IT security incidents and specifies its obligations under applicable regulatory requirements. This Plan shall be subject to review on a need basis, such as upon changes in operational situations, and at least once a calendar year. This Plan shall be reviewed and approved by the Executive Committee.

3 Roles and responsibilities — Security Incident Response Team (SIRT)

Role	Responsibilities	Responsible party
Incident Response Lead (IRL)	Lead SIRT; keep the Plan documented and up to date; direct internal and external communication	Head of IT
Incident Response Technical Lead (IRTL)	Contain the incident; investigate; report findings to SIRT	VP, Information Security
Incident Response Regulatory Lead (IRRL)	Coordinate regulatory and law-enforcement reporting; authorise onsite investigation	Head of Compliance

4–12 Procedure (summary)

- Detection: end-user reporting, SOC reporting, threat hunting, third-party notification, threat intelligence feeds, device alerts.
- Verification by IRTL; IRL activates the plan for true positives suggesting a breach.
- Triage and scoping: affected assets, BIA rating, impact severity (Minor / Moderate / Critical / Catastrophic) and urgency. IRL alerts the CEO and senior management; initial incident report within 24 hours. A severe incident must be reported to the regulator within the required timeframe.
- Containment, eradication, recovery (per the BCP if activated), remediation (root cause analysis), post-incident report with lessons learned and updates to policy, technology and training.

13 Testing and updates

This Plan will be tested at least annually using walkthroughs and practical simulations of incident scenarios. SIRT will record observations and lessons learned and implement improvements. IRL will ensure the Plan is updated and communicated to SIRT.

Section 14 provides playbooks for malware, unauthorised wireless access points, loss of equipment and non-compliance with the Group Cyber Security Policy.

DOCUMENT D09 · ABC BANK

Cyber Risk Management Policy (v1.0)

Full document, abridged. Dated 31 December 2024.

Document details	
Title	Cyber Risk Management Policy
Version	1.0
Owner	Head of IT
Approval date	(blank)
Effective date	(blank)

Version	Issue date	Summary of key changes	Prepared / updated by	Reviewed / approved by
1.0	31 Dec 2024	First draft	VP, Information Security	(blank)

Purpose and scope

To establish a framework for managing cyber risks to ensure the confidentiality, integrity and availability of information assets in accordance with ISO 27001. Applies to all ABC Bank digital assets (information assets, IT infrastructure, communication systems, cloud services) and to all employees, contractors and third-party service providers with access.

Roles and responsibilities

Role	Responsibilities
Head of IT (Approver)	Review identified risks; evaluate risk treatment options; decide on risk acceptance; communicate with stakeholders; risk reporting
Information Security Cyber Risk Assessor	Conduct risk assessments; develop risk treatment strategies; document findings and recommendations

Process

- Threat assessment: identify assets; threat modelling using MITRE ATT&CK; weakness identification; exploitability; threat index.
- Impact assessment using the BIA classification; risk statements and ratings (threat index + impact).
- Risk treatment: mitigation, transfer, acceptance, avoidance.
- Risk registry: approved risks registered; regular review of treatment progress; annual update.
- Exceptions require formal justification, are approved by the Head of IT, and are time-bound.

DOCUMENT D10 · ABC BANK

IT Key Risk Indicators — draft for discussion (August 2025)

Extract of a draft KRI worksheet prepared by Operational Risk for IT. Actual results columns (Oct–Dec 2025) are blank.

Proposed KRI	Frequency	Green	Amber	Red	Status
Breaches in SLA with key IT service providers; major service disruptions	Monthly	0	1	>1	Proposed for discussion
System up-time	Monthly	≥ 99.5%	99–99.5%	< 99%	Proposed; definition TBC
End-of-life systems without support; change-related outages	Monthly	0	1	>1	Proposed for discussion
Number of security incidents (breaches, phishing, DoS …)	Monthly	0	1	>1	Proposed (cyber-related)
Cyber security score	Monthly	TBC	TBC	TBC	“To discuss: do we have this?”
Phishing test failure rate	Monthly / annual	< 10%	10–20%	> 20%	“To discuss: do we have this?”
Outstanding high-risk cyber audit actions	Monthly	≤ 2	3–5	> 5	Proposed (cyber-related)
Security awareness training completion	Annual	> 85%	70–85%	< 70%	Proposed (cyber-related)

DOCUMENT D11 · ABC BANK

Terms of Reference — Audit Committee

Version 4.0, 27 September 2023 (extract). Duties relating to the external auditor and to financial statements are omitted.

1 General

The Audit Committee of ABC Bank Limited was established by resolution of the Board of Directors on 25 January 2013. These Terms cover ABC Bank, its branches and representative offices.

The principal function of the Audit Committee is to assist the Board by providing an independent review of the effectiveness of the financial reporting process and the internal control system of the bank. In discharging its duties the Committee shall have due regard to applicable laws, regulations and guidelines issued by the relevant regulators, including the HKMA Supervisory Policy Manual.

The internal audit function and the internal auditor of the bank shall have a direct reporting line to the Audit Committee.

2 Membership

Members are appointed by the Board from among the non-executive directors; not fewer than three, at least one an independent non-executive director (INED), preferably INEDs in the majority. The chair is an INED appointed by the Board.

3 Meetings

The CEO, the CFO, other senior executives as the CEO deems appropriate, the Head of Internal Audit, and representatives of the external auditor and/or the internal audit service provider normally attend. The Committee may meet the external and internal auditors without executive directors or management present. Meetings are held not less than three times a year.

4 Authority

The Committee is authorised by the Board to investigate any activity within these Terms, to seek any information it requires from any employee, and to obtain outside independent professional advice at the bank's expense.

5 Duties (extract)

Supervision of internal auditors

- (g) make recommendations to the Board on the appointment and dismissal of the Head of Internal Audit and, where internal audit service providers are used, on their appointment, re-appointment, removal and terms of engagement;
- (h) receive internal audit reports and ensure that management (with appropriate involvement of the control functions) takes necessary corrective action in a timely manner to address control weaknesses, non-compliance with policies, laws and regulations, or other issues identified by the auditors;
- (i) review, and recommend to the Board for approval, the internal audit plan and programme; oversee co-ordination between internal and external auditors; ensure the internal audit function is adequately resourced and has appropriate standing; and review and monitor the effectiveness of the internal audit function;

Oversight of internal control

- (l) oversee the bank's financial controls and internal control;
- (m) discuss with management any matters relating to the internal control system and oversee that management has discharged its duty to establish and maintain an effective internal control system;
- (n) consider any findings of major investigations of internal control matters, as delegated by the Board or on its own initiative, and management's response;

Others

- (t) bring major findings of examination reports by regulatory bodies to the attention of the Board, and review management's follow-up actions;
- (u) report to the Board on matters relating to the duties of the Committee set out in these Terms;

6 Reporting procedures

Full minutes are kept by the company secretary and record in sufficient detail the matters considered and decisions reached. The Committee reports back to the Board and keeps it fully informed of its decisions and recommendations.

8 Review and updates

These Terms shall be reviewed on an annual basis and as needed. Amendments are recommended by the Audit Committee and approved by the Board.

Version	Issue date	Updated by	Approved by
1.0	25 January 2013	CEO	Board
2.0	1 November 2013	Legal function	Board
3.0	17 May 2018	Legal function	Audit Committee and Board
4.0	27 September 2023	Legal function	Audit Committee and Board

DOCUMENT D12 · ABC BANK

Internal Audit Policy

Group policy, version 1.0 (extract). Owner: Head of Internal Audit. Classification: For internal use only.

Title	Version	Owner	Approval / effective date	Approved by
Internal Audit Policy	1.0 (first issue)	Head of Internal Audit	14 June 2019	Audit Committee

Role of the Internal Audit function

The Internal Audit (IA) function is an independent, effective and objective function established by the Audit Committee (AC) to examine and evaluate the adequacy, functioning, effectiveness and efficiency of the internal control system and all other elements of the system of governance.

IA supports the AC in identifying strategies and guidelines on internal control and risk management, and provides senior management with analysis, appraisals, recommendations and information on the activities reviewed. It also carries out assurance and advisory activities for senior management. IA has full, free and unrestricted access to all records, property and personnel; the Head of IA has free and unrestricted access to the AC.

Professionalism and independence

IA members adhere to the Institute of Internal Auditors' mandatory guidance (Definition of Internal Auditing, Code of Ethics, International Standards). The Head of IA reports to the Audit Committee and holds no operational responsibility. IA remains free from interference in audit selection, scope, procedures, frequency and timing. The Head of IA may assign external resources to all or part of an audit when resources are limited or specific skills are required.

Internal Audit plan

Annually, the Head of IA proposes an IA plan to Risk Management before it is submitted to the Audit Committee for approval. The plan is developed from a prioritisation of the audit universe using a risk-based methodology, taking into account all activities, the complete system of governance, expected developments and innovations, and the input of senior management. Planning takes account of deficiencies found in previous audits and of any new risk detected.

The Head of IA reviews and adjusts the plan every six months in response to changes in the business, risks, operations, systems, controls and findings. Any significant deviation from the approved plan is communicated to, and approved by, the AC.

Audit approach

The audit approach is risk-based and focuses on controls. The plan is drawn up on the basis of a documented audit risk analysis, carried out at least once a year and reviewed every six months. The scope of auditing covers the adequacy and effectiveness of the bank's governance, risk management and internal control processes.

Reporting and monitoring

After each engagement a written audit report is issued to the auditee and the auditee's hierarchy. It states the significance of the issues found, the agreed corrective actions and their deadlines. IA monitors follow-up of issues raised and agreed actions.

Quarterly, the Head of IA provides the AC with a report on activities and significant issues in the period and a proposed action plan. The AC decides what action is to be taken on each issue and ensures it is carried out. In particularly serious situations the Head of IA informs the AC immediately.

Quality and improvement programme

IA maintains a quality and improvement programme covering all aspects of audit activity, including ongoing internal assessments and an external assessment at least every five years.

Issuer, approval and review

The Head of IA is in charge of this Policy. The Policy is approved by the Board of Directors. It is effective from 14 June 2019 and is subject to review at least annually.

DOCUMENT D13 · ABC BANK

Board minutes — approval of the 2024 and 2025 Internal Audit plans

Extracts of two Board meeting minutes. Attendees shown by role; fees removed.

Minutes of Board meeting, 7 March 2024 — item 6.7

Present: Vice-chairman and CEO (chair of the meeting); Director and CFO; four non-executive directors. In attendance: Head of Legal; AVP, Legal; shareholder observer.

2024 Internal Audit Plan and Internal Audit Fees. It was NOTED that the Audit Committee has recommended to the Board of Directors for approval the proposed 2024 internal audit plan and internal audit fees of the Company, as set out in the co-sourced internal audit provider's presentation tabled at the meeting (Annex 3). The 2024 internal audit will cover:

- (i) Treasury and investment (Hong Kong)
- (ii) Financial reporting (Hong Kong and overseas branch)
- (iii) Business Continuity Management (Hong Kong)
- (iv) Compliance and AML/CFT (Hong Kong and overseas branch)
- (v) Credit loss provisioning (Hong Kong)
- (vi) Trade finance operations — provisional (overseas branch)
- (vii) Cybersecurity (Hong Kong)

The Board, having considered and discussed the engagement and the 2024 Internal Audit Plan, RESOLVED that they be approved and adopted by the Company. [Fees removed.]

Minutes of Board meeting — 2025, Q1 (24 March 2025) — item 6.8

Present: Chairman (chair of the meeting); Vice-chairman and CEO; Director and CFO; five non-executive directors. In attendance: Head of Legal; AVP, Legal; shareholder observer.

2026 Internal Audit Plan and Internal Audit Fees [heading as in the signed minutes]. It was NOTED that the Audit Committee has recommended to the Board of Directors for approval the proposed 2025 internal audit plan and internal audit fees, as set out in the co-sourced internal audit provider's presentation (Annex 4). The 2025 internal audit will cover:

- (i) Finance (Hong Kong and overseas branch)
- (ii) Regulatory capital reporting (overseas branch)
- (iii) Treasury and investment (Hong Kong)
- (iv) Product development and pricing (Hong Kong)
- (v) Third party and vendor management (Hong Kong)

The Board, having considered and discussed the engagement and the 2026 Internal Audit Plan, RESOLVED that they be approved and adopted by the Company. [Fees removed.]

Annexes 3 and 4 (the audit plan presentations) were not provided.

DOCUMENT D14 · ABC BANK

Internal Audit report — Internal Controls Review: Cybersecurity

Report dated 3 March 2025, issued by the co-sourced internal audit provider. Fieldwork November 2024 – January 2025. Extract; machine names, file paths and product names removed.

1 Executive summary

In view of increased regulatory expectations on corporate governance and controls, ABC Bank requested its out-sourced internal auditor to perform a security review of its network and endpoint security, to help ensure cybersecurity resilience and recommend improvements to operational resilience. Management comments on each observation are incorporated.

Scope. (1) External reconnaissance to identify the bank's external-facing services, followed by automated and manual penetration testing and exploitation attempts on vulnerable elements; (2) simulated real-world attacks to evaluate preventive and detective capabilities against the latest threats, covering 30 tactics, techniques and procedures in the MITRE ATT&CK framework.

Work performed. Interviews with key management and process owners, and security testing designed to assess the adequacy and effectiveness of the design and operation of internal controls over cybersecurity.

Overall assessment	High	Medium	Low	Informational	Total
Number of findings	0	4	2	0	6

2 Summary of observations

Ref	Observation	Rating	Owner	Target date
3.1	Insecure remote desktop software usage (no MFA; credentials stored on a shared drive)	Medium	Head of IT / VP Information Security	1 Nov 2025
3.2	Insufficient user awareness on handling sensitive information (credentials and personal data on shared drives)	Medium	Head of IT / VP Information Security	31 Dec 2025
3.3	Insufficient data loss prevention (test files exfiltrated undetected)	Medium	Head of IT / VP Information Security	30 Sep / 1 Nov 2025
3.4	Insecure network segmentation within the internal network (RDP reachable from the user subnet to critical servers)	Medium	Head of IT / VP Information Security	31 Dec 2025
3.5	Endpoint and network protection against malicious activities could be enhanced	Low	Head of IT / VP Information Security	30 Sep 2025
3.6	Email security could be enhanced	Low	Head of IT / VP Information Security	30 Jun 2025 / 30 Jun 2026

3 Example of a detailed observation (3.3)

Observation	**Test files containing personal data were exfiltrated from a testing machine inside the bank's network without detection or blocking — via file-sharing websites, public cloud storage and a publicly hosted web server.**
Implication	Without effective data loss prevention (DLP) controls, attackers and malicious insiders may exfiltrate sensitive information, including customers' personal data.
Recommendation	Quick win: restrict access to file-sharing sites and public cloud storage unless required and authorised. Long term: assess a DLP solution to detect and prevent unauthorised exfiltration.
Management response	Implement web content filtering; deploy an endpoint DLP policy for labelled files.
Rating / owner / date	Medium · Head of IT / VP Information Security · 30 Sep 2025 (action 2), 1 Nov 2025 (action 1)

Appendix — risk rating scale

Rating	Definition
High	A weakness which could cause, or is causing, severe disruption to, or significant impact on, the bank.

Rating	Definition
Medium	Of lesser importance but still necessary for improving the overall environment and system integrity.
Low	A minor weakness with minimal impact; may represent good practice to further enhance security posture.
Informational	Not a threat to the system; recommendation based on experience and industry practice.

Limitations and disclaimer (extract)

“This is a point-in-time review of a complex area … the maintenance of an adequate system of internal control is the responsibility of management.”

“Our work does not constitute an audit or other assurance engagement in accordance with applicable professional standards. Accordingly, we provide no audit opinion, attestation or other form of assurance with respect to our work.”

Distribution: the report is for the bank’s use; a copy may be provided to the bank’s regulators and statutory auditor.

DOCUMENT D15 · ABC BANK

Internal Audit follow-up tracker — IT and cyber actions (2023 and 2024 audits)

Extract of the issue tracker maintained for the Audit Committee. Responsible persons shown by role.

No.	Report (date)	Action (abridged)	Owner	Risk	Due	Status
2023-14	IT general controls (6 Mar 2024)	(i) Review and obtain approval of the IT Security Incident Response Plan; (ii) implement IT general control and cyber risk framework	IT	High	31 Mar 2024 / 31 Dec 2024	Closed (evidence: email 6 Jan 2025)
2023-15	IT general controls (6 Mar 2024)	Strengthen privileged access management (policy, tool, SIEM detection)	IT	High	31 Dec 2024	Closed
2023-18	IT general controls (6 Mar 2024)	Failure to adhere to the IT Security Incident Response Plan: awareness training; tabletop exercises; incident tracking	VP Information Security	High	31 Dec 2024	Closed (tabletop 9 Dec 2024)
2023-20	Cybersecurity (6 Mar 2024)	Excessive external service exposure: restrict admin portal and SSH; asset owner register	Head of IT / VP IS	High	31 Mar / 31 Dec 2024	Closed
2023-23	Cybersecurity (6 Mar 2024)	Outdated application / server versions: upgrade unsupported software	Head of IT / VP IS	Low	31 Dec 2024	Extended to Q4 2025 — Closed
2024-14	Cybersecurity (3 Mar 2025)	Insecure remote desktop software usage	Head of IT / VP IS	Medium	1 Nov 2025	(blank)
2024-16	Cybersecurity (3 Mar 2025)	Insufficient data loss prevention	Head of IT / VP IS	Medium	30 Sep / 1 Nov 2025	(blank)
2024-17	Cybersecurity (3 Mar 2025)	Insecure network segmentation	Head of IT / VP IS	Medium	31 Dec 2025	(blank)
2024-19	Cybersecurity (3 Mar 2025)	Enhance email security	Head of IT / VP IS	Low	30 Jun 2025 / 30 Jun 2026	(i) Closed